

SÍNTESIS EJECUTIVA: GQM+PRAGMATIC PARA OWASP SAMM

Marco Integrativo + Matriz de Evaluación — Resumen Operacional

Versión: 1.0 | **Fecha:** Enero 2026 | **Público:** CISOs, Estrategas

Documentos Asociados:

- marco_gqm_pragmatic.md — Marco teórico completo (70+ páginas)
- matriz_pragmatic_evaluacion.md — Evaluación de 30+ métricas (50+ páginas)

I. RESUMEN EJECUTIVO (5 MIN READ)

Objetivo

Proporcionar a organizaciones españolas un **framework riguroso, trazable y operacional** para:

1. **Conectar** objetivos nacionales (NIS2, CRA, GDPR) — métricas técnicas
2. **Evaluar** cada métrica contra 9 criterios de calidad (PRAGMATIC)
3. **Priorizar** implementación con confianza metodológica
4. **Gobernar** portfolio de métricas de ciberseguridad

Metodología

3 Capas de Rigurosidad:

CAPA 1: GQM (Goal-Question-Metric)

- └ Top-Down: Objetivo Nacional → Goal → Question → Metric
[Harvard/NASA proven, 25+ años de aplicación industrial]

CAPA 2: GQM+Strategies (Basili, Fraunhofer)

- └ Links: National Goals → Business Strategies → Software-specific Goals
[Explícitamente conecta negocio con métricas técnicas]

CAPA 3: PRAGMATIC (Brothy, Hinson)

- └ Evalúa cada métrica: P-R-A-G-M-A-T-I-C (9 criterios × 5-point scale)
[Filtrar métricas impuras, elige las que realmente importan]

Hallazgos Clave

Finding 1: Trazabilidad Completa es Posible

Ejemplo real:

Objetivo Nacional (NIS2 Art. 20)
↓ "Gestionar vulnerabilidades críticas en <24h"
GQM Goal (Operaciones)
↓ "Mejorar velocidad remediación"
GQM Questions (Operaciones)
↓ Q1: "¿Cuál es promedio MTTR?" Q2: "¿% cumplimiento SLA?"
Métricas (SAMM Operations Practice)
↓ M1: MTTR Critical = promedio horas remediación crítica
↓ M2: MTTR Compliance % = % que cumplen SLA <24h
Evaluación PRAGMATIC
↓ M1: 88.9% (muy buena) → ADOPTAR INMEDIATAMENTE

Cada métrica es **traceable 4 niveles arriba** a objetivo regulatorio.

Finding 2: Rankings Claros de Métricas

Top 5 Métricas (PRAGMATIC >90%):

Rank	Métrica	PRAGMATIC	Razón
1	SAST Integration Coverage	95.6%	Predictivo, accionable, automático
2	EPSS Score Adoption	93.3%	Transforma vulnerabilidad classification
3	MTTD Mean	91.1%	Operacionalmente crítica
4-8	MTTR, Threat Models, Patch Compliance, Pre-Prod Closure	88.9%	Solidez equilibrada

Métricas a Evitar (<75%):

- Training Completion Rate (77.8%) — mejor con comportamiento complementario
- SIEM False Positive Rate (80%) — requiere definición muy clara

Finding 3: Portfolio Balanceado (Year 1 Recommendation)

Quick Wins (Q1 2026) — 5 métricas, 3 semanas, €10k:

- SAST Coverage, MTTD, Phishing Click Rate, Scan Coverage, Build Gate Rate

Consolidation (Q2 2026) — 4 métricas adicionales, €15k

Expansion (Q3-Q4 2026) — Full suite, €40k total

Result: Incremento de ~40% en security metrics maturity sin sobrecarga.

II. MARCO INTEGRATIVO GQM+PRAGMATIC (15 MIN READ)

II.1 Estructura 4-Niveles

Nivel 0: Objetivos Nacionales Españoles (2025-2026)

Regulación + Derivados:

Marco Legal	Objetivo Clave	Horizonte	SAMM Link
NIS2	Resiliencia crítica L1.8+	Oct 2024 (vencido)	Gobernanza, Operaciones
CRA	Secure by design L1.55+	Sept 2026	Diseño, Implementación, Verificación
DORA	Resiliencia digital (sector fin)	2024-2026	Operaciones, Gobernanza
GDPR	Protección datos; capacitación	Vigente	Implementation, Training

3 Objetivos Estratégicos Derivados:

1. Eliminar vulnerabilidades críticas en 50% tiempo (MTTD/MTTR)
2. Alcanzar SAMM L1.8 en Diseño + Verificación
3. 90%+ empleados con capacitación validada (comportamiento)

Nivel 1: GQM Goals (Sample)

GOAL 1: Mejorar Gobernanza AppSec

Activity: Implementar
Focus: Madurez en documentación y estrategia
Object: Programa AppSec
Magnitude: SAMM Governance 1.4 → 1.8 (+29%)
Timeframe: 18 meses (Q2 2026)
Context: Operador esencial español; financiero/telecom
Stakeholders: CISO, CIO, Board
Rationale: NIS2 Art. 20 + CRA Annex I exigen governance formalizado

GOAL 2: Acelerar Detección Incidentes (MTTD)

Activity: Mejorar
Focus: Velocidad de detección
Object: Incidents en apps críticas
Magnitude: MTTD: 48h → 4h (12x mejora)
Timeframe: 12 meses (Q2 2026)
Context: SIEM existente; SOC 2-3 FTE; 500GB logs/día
Stakeholders: SOC Manager, CISO
Rationale: INCIBE 2024: promedio 48h; NIS2 requiere <4h

Nivel 2: GQM Questions (Sample per Goal)

Para GOAL 1 (Gobernanza):

- Q1.1: ¿Existe estrategia AppSec documentada formalmente?
- Q1.2: ¿Cómo se comunica y revisa la estrategia?
- Q1.3: ¿Existen KPIs para medir éxito?
- Q1.4: ¿% de equipos alinean actividades con estrategia?

Para GOAL 2 (MTTD):

- Q2.1: ¿Cuál es MTTD promedio? (Percentil mean, median, P95)
- Q2.2: ¿% de detecciones son automáticas (SIEM) vs. externas?
- Q2.3: ¿Cuáles son causas raíz de retrasos?
- Q2.4: ¿Cómo correlaciona MTTD con tipo de incident?

Nivel 3: Métricas GQM Específicas

Por cada Pregunta, 1-2 Métricas cuantificables:

Para Q1.1 (¿Estrategia documentada?):

- **M-GOV-01a:** Strategy Documentation Score (0-3: existence, update, access)
- **M-GOV-01b:** Strategy Stakeholder Awareness (%)

Para Q2.1 (¿MTTD promedio?):

- **M-OPS-01a:** MTTD Mean (hours)
- **M-OPS-01b:** MTTD Median (hours)
- **M-OPS-01c:** MTTD P95 (hours)
- **M-OPS-01d:** Autonomous Detection % (# auto-detected / # total)

II.2 Evaluación PRAGMATIC (9 Criterios)

Cada métrica es evaluada contra:

Criterio	Pregunta	Escala
Predictivo	¿Predice riesgo futuro o comportamiento próximo?	1-5
Relevante	¿Importa a stakeholders (negocio/regulación/técnico)?	1-5
Accionable	¿Permite acciones concretas y viables?	1-5
Genuino	¿Refleja realidad sin artificio o gaming?	1-5
Meaningful	¿Es significativo, no trivial?	1-5
Acurado	¿Se mide con precisión y confiabilidad?	1-5
Toportuno	¿Está disponible con frecuencia operacional?	1-5
Independiente	¿Es auto-interpretable sin contexto externo?	1-5
Costeable	¿Costo razonable vs. valor aportado?	1-5

Score Final: (P+R+A+G+M+A+T+I+C) / 9 = Percentage 0-100%

Interpretation:

- >90%: ★★★★★ ADOPTAR INMEDIATAMENTE
- 80-89%: ★★★★ ADOPTAR
- 70-79%: ★★★ ADOPTAR CON COMPLEMENTOS
- <70%: ✖ EVITAR O REPENSAR

II.3 Ejemplo: MTTD Mean Evaluation

Métrica: MTTD Mean (promedio horas desde incident occurrence hasta detection)

P = 5/5 (FUERTE predictor: cada hora reduce recovery window)
R = 5/5 (Crítico: NIS2, regulación financiera, board concern)
A = 5/5 (Accionable: inversión SIEM, hiring SOC, automation)
G = 4/5 (Refleja realidad; pero depende definición "detection")
M = 5/5 (Muy meaningful: 48h vs 4h es 12x diferencia)
A = 4/5 (Medible si logs confiables; pequeña ambigüedad)
T = 5/5 (Diario disponible de SIEM)
I = 3/5 (Requiere contexto: "¿cómo se define detection?")
C = 5/5 (Automático de SIEM; costo \$0)

PRAGMATIC SCORE: (5+5+5+4+5+4+5+3+5) / 9 = 41/45 = 91.1% ✓ ADOPTAR

III. MATRIZ DE EVALUACIÓN COMPLETA

III.1 Rankings Top 15 Métricas

Todos los datos de matriz_pragmatic_evaluacion.md, resumen ejecutivo:

Rank	Métrica	PRAGMATIC	Dominio	Acción
1	SAST Integration Coverage	95.6%	Implementation	Q1 Quick Win
2	EPSS Score Adoption	93.3%	Vulnerabilities	Q3 Expansion
3	MTTD Mean	91.1%	Operations	Q1 Quick Win
4	KPI Tracking Coverage	88.9%	Governance	Q2 Consolidation
5	Threat Model Coverage	88.9%	Design	Q2 Consolidation
6	Pre-Prod Vuln Closure Rate	88.9%	Implementation	Q2 Consolidation
7	MTTR Critical	88.9%	Operations	Q2 Consolidation
8	Patch Compliance Rate	88.9%	Operations	Q2 Consolidation
9	Phishing Click Rate	86.7%	Training	Q1 Quick Win
10	Strategy Documentation Score	86.7%	Governance	Q2 Consolidation

Full list: 30+ métricas evaluadas en documento matriz_pragmatic_evaluacion.md

III.2 Portfolio Year 1 (Recomendado)

Quick Wins (Q1 2026 — Start Immediately)

5 métricas, 3 semanas, €10k, <15% effort increase

1. M-IMP-01: SAST Integration Coverage (95.6%)
→ Source: CI/CD logs | Frequency: Daily | Owner: DevSecOps
2. M-OPS-01: MTTD Mean (91.1%)
→ Source: SIEM logs | Frequency: Daily | Owner: SOC Manager
3. M-TRAIN-02: Phishing Click Rate (86.7%)
→ Source: Phishing simulator | Frequency: Monthly | Owner: Security Awareness Lead
4. M-VULN-01: Vulnerability Scan Coverage (80%)
→ Source: Scanner logs | Frequency: Monthly | Owner: Vulnerability Manager
5. M-IMP-02: Build Gate Block Rate (80%)
→ Source: CI/CD logs | Frequency: Weekly | Owner: DevSecOps

Consolidation (Q2 2026)

4 adicionales, +4 semanas, €15k

- 6. M-DES-01: Threat Model Coverage (88.9%)
- 7. M-OPS-02: MTTR Critical (88.9%)
- 8. M-OPS-03: Patch Compliance Rate (88.9%)
- 9. M-VER-02: Penetration Test Frequency (82.2%)

Expansion (Q3-Q4 2026)

Coverage complete, €40k total, foundational metrics maturity

- 10. M-GOV-02: KPI Tracking Coverage (88.9%)
- 11. M-SIEM-01: Data Source Coverage (82.2%)
- 12. M-VULN-02: EPSS Score Adoption (93.3%)
- 13. Additional domain-specific metrics

IV. CÓMO USAR ESTOS DOCUMENTOS

Step 1: Leer "Marco Integrativo" (1-2 horas)

Purpose: Entender la arquitectura GQM+PRAGMATIC

Target: CISOs, Architects

Output: "Entiendo cómo conectar mi objetivo NIS2 a métricas técnicas"

Sections clave:

- Parte I: Objetivos Nacionales españoles
- Parte II: Estructura 4-niveles (Goals → Questions → Metrics)
- Parte III-IV: Ejemplos detallados por dominio SAMM
- Parte V: Evaluación PRAGMATIC con rúbrica

Step 2: Revisar "Matriz Evaluación" (30-45 min)

Purpose: Decidir cuáles métricas implementar

Target: Measurement Team, Governance Council

Output: "Estos son los top 10 indicadores, en este orden de prioridad"

Sections clave:

- Parte I: Evaluaciones detalladas de 30+ métricas
- Parte II: Rankings y scores
- Parte III: Portfolio recomendado (Quick Wins → Consolidation → Expansion)

Step 3: Implementación Operacional (Ongoing)

Phase 1: Quick Wins (Weeks 1-3, Q1 2026)

Tarea: Implementar 5 métricas top (PRAGMATIC >85%)

- 1. Extraer SAST data de CI/CD (automático)
- 2. Configurar MTTR tracking en SIEM (1 day)
- 3. Activa simulador phishing (plug-and-play)
- 4. Vulnerability scan reporting (1 day)
- 5. Build gate analytics (1 day)

Result: 5 métricas activas; baseline establecido

Phase 2: Governance (Month 1-3, ongoing)

Tarea: Establecer ownership + governance

1. Owner por métrica (responsable reporte)
2. Escalation thresholds (ej: si MTTD >8h → alert)
3. Review cadence (semanal/mensual/trimestral)
4. Audience (Board, CISO, Security Team, Architects)

Phase 3: Roadmap (Quarters 2-4)

Q2: Añadir 4 métricas (consolidation)

Q3: Expandir a 12-15 métricas core

Q4: Optimizar, revisar PRAGMATIC scores, refinar

V. RECOMENDACIONES FINALES

Recomendación 1: Prioriza Predictive + Accionable

Error común: Implementar métricas que "suenan bien" pero no predicen nada.

Better: Enfócate en PRAGMATIC >85% donde **P** ≥ 4/5 AND **A** ≥ 4/5

Examples de buenas métricas:

- SAST Coverage: P=5 (predice bugs), A=5 (agrega apps a pipeline)
- MTTD Mean: P=5 (predice impacto), A=5 (inversión SIEM)

Recomendación 2: Evita Métrica Única por Dominio

Error común: Un solo indicador por SAMM function (ej, solo "MTTD" para Operations)

Better: 2-3 métricas complementarias por dominio

Example (Operations):

- **M1:** MTTD Mean (velocidad detección)
- **M2:** MTTR Critical (velocidad remediación)
- **M3:** Patch Compliance % (preventiva)
- **M4:** Autonomous Detection % (calidad)

Diferentes ángulos, cobertura equilibrada.

Recomendación 3: Conecta a OKRs de Negocio

Template:

OKR de Negocio: "Reducir riesgo operacional en 30% para 2026"



CISO Objective: "Mejorar incident response (MTTD/MTTR)"



SAMM Goal (GQM): "Mejorar Operations a L1.8"



Métricas (GQM): MTTD Mean, MTTR Critical, Patch Compliance %



Reporting: Board ve "Risk reduction: -12% YoY" (agregado de métricas)

Cada métrica tiene "story" que conecta al negocio.

Recomendación 4: Review PRAGMATIC Scores Anualmente

Métricas evolucionan. Lo que es PRAGMATIC >90% hoy puede cambiar.

Annual Review:

¿Has introducido nueva herramienta SIEM con mejor data?

→ MTTD coverage puede mejorar de 4/5 a 5/5 (más preciso)

¿Ha cambiado regulación?

→ Algunos scores de Relevancia pueden bajar/subir

¿Team crece?

→ Costo de recopilación baja, viabilidad sube

Revisa PRAGMATIC scores; ajusta portfolio si es necesario.

VI. CONCLUSIÓN

What You Get

- ✓ **Trazabilidad completa:** NIS2/CRA → GQM Goals → Métricas técnicas
- ✓ **Evaluación rigurosa:** 9 criterios, scoring transparente, sin ambigüedad
- ✓ **Portfolio operacional:** 5 quick wins + roadmap 12 meses
- ✓ **Guía implementación:** Paso a paso, roles, frecuencias, ownership
- ✓ **Spanish context:** Objetivos nacionales, regulación, sectores críticos

Value Delivered

- For CISO: Métrica portfolio defendible ante Board, traceable a regulación
- For Architects: Cada métrica conecta a objetivo técnico concreto
- For DevSecOps: Automatización clara (SAST, SIEM, scanners)
- For Governance: Ownership explícito, governance structure, review cadence
- For Auditors: Trazabilidad NIS2/CRA/GDPR demostrable

Next Steps

1. Leer Marco Integrativo (2h) → Entender la arquitectura
2. Revisar Matriz Evaluación (45 min) → Seleccionar top 5 métricas
3. Implementar Quick Wins (Weeks 1-3) → 5 métricas activas
4. Gobernar (Ongoing) → Ownership, escalation, review
5. Expandir (Q2-Q4 2026) → Portfolio completo de 12-15 métricas

Documentos Descargables:

- marco_gqm_pragmatic.md — Marco teórico + 100+ ejemplos
- matriz_pragmatic_evaluacion.md — Evaluación exhaustiva + rankings
- sintesis_ejecutiva.md — Este documento

Soporte:

Contacta a tu equipo de medición o consejero de ciberseguridad para mapeo a contexto específico de tu organización.

Desarrollado aplicando GQM (Basili, NASA/UMD), GQM+Strategies (Fraunhofer), y PRAGMATIC (Brotby/Hinson) a OWASP SAMM v2 y contexto normativo español 2025-2026.